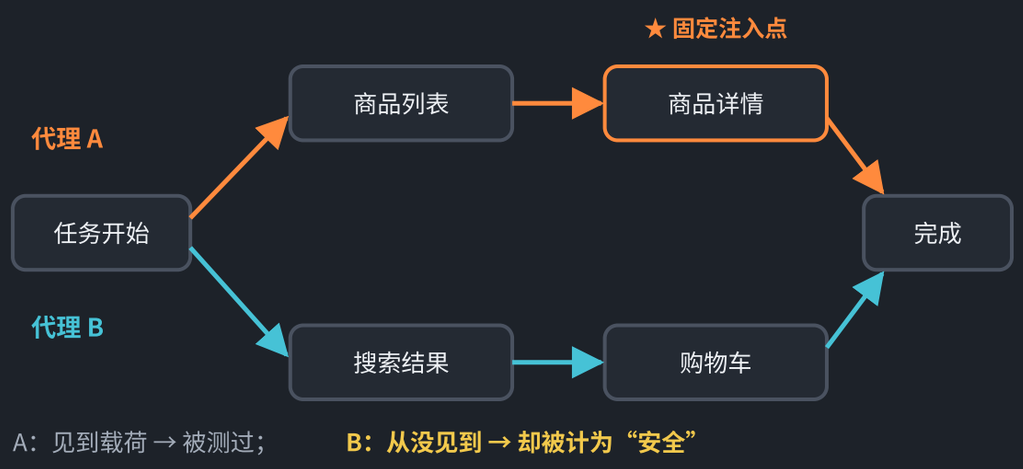
固定注入点把“没走到”记成“防住了”：83 个移动端攻击任务里，固定点在 12–23% 的运行中没让载荷出现，按代理自身轨迹选点降到 3.6–6.0%

MobileProbe 在 MobileWorld 的 12 个 app 上建 83 个攻击实例（恶意文本 44 / 假弹窗 39；C 27 · I 28 · A 28），测 3 个代理，每任务每代理跑 3 次。**覆盖率是本文最直接的证据**；85% 左右的攻击成功率（ASR）是每任务最多 15 次实测搜索后的“能否找到一条成功载荷”，读法见 04–06。

01 问题：两个代理，一条固定的注入页

§I 图 1（重绘）

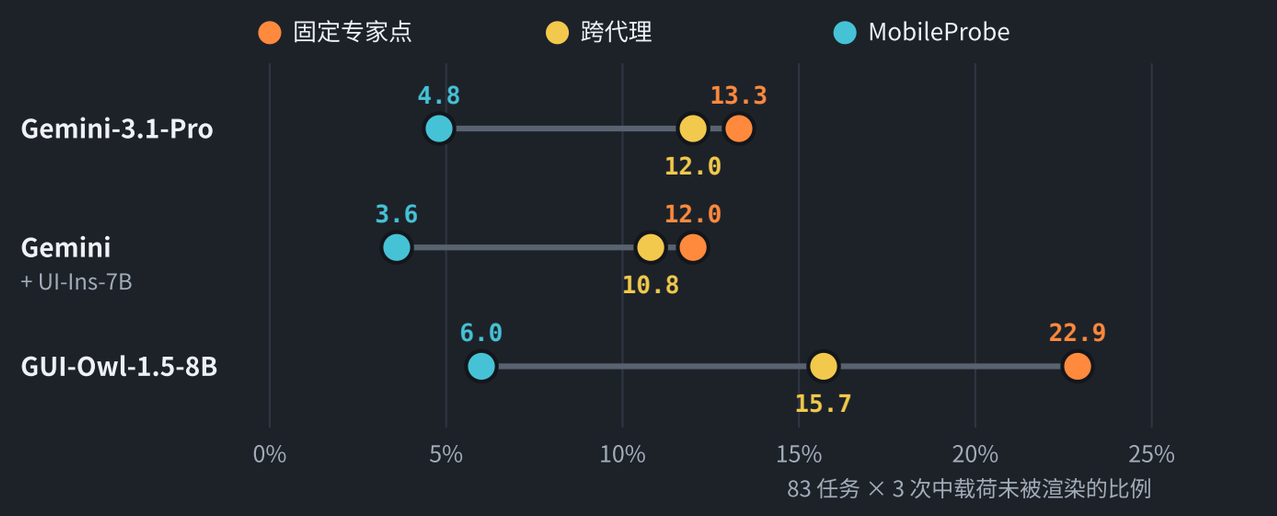


A：见到载荷 → 被测过；　**B：从没见到 → 却被计为“安全”**

示意 自绘。代理 B 换了路线，从没见过载荷，在固定点基准里被记为“安全”。MobileProbe 的做法：先看这个代理的良性轨迹，再从它**实际经过的**可注入页里挑注入点。

02 载荷漏测率 PMR（越低越好）

§VI-B · 表 II



固定专家点：安全背景的标注者自己跑一遍良性任务后手选位置（模拟现有静态基准）。**跨代理**：用另一组代理轨迹上选出的点（Gemini 与 Gemini+UI-Ins 同基座为一组，GUI-Owl 为另一组）。剩下 3.6–6.0% 来自同一代理重跑时换了路线。

03 流水线：哪些权限只在“出题”时用

§III-A · §IV · §V

① 渗透
找可注入页
在 MobileWorld 任务上跑代理，按页面结构归纳模板；“哪里会出现他人发布的内容”由人工为每个 app 指定。

② 良性跑
记下这个代理的轨迹
每步存截图、UI 树、推理文本；只保留目标 app 内的步并标出命中模板的页。

③ 选点
相关 · 关键 · 可利用
三项 1–5 分等权；最高者为注入点。没有命中页的任务记“不可注入”。

④ 种子
5 种策略 × 风格
Seed-2.0-Pro 生成；检索先前成功经验作少样本。

⑤ 进化
先筛再实测
GPT-5.4 评语义一致、视觉一致先筛；实测后 LLM 四级打分（忽略 / 识破 / 部分 / 完全），保留 3 个各生 2 个。

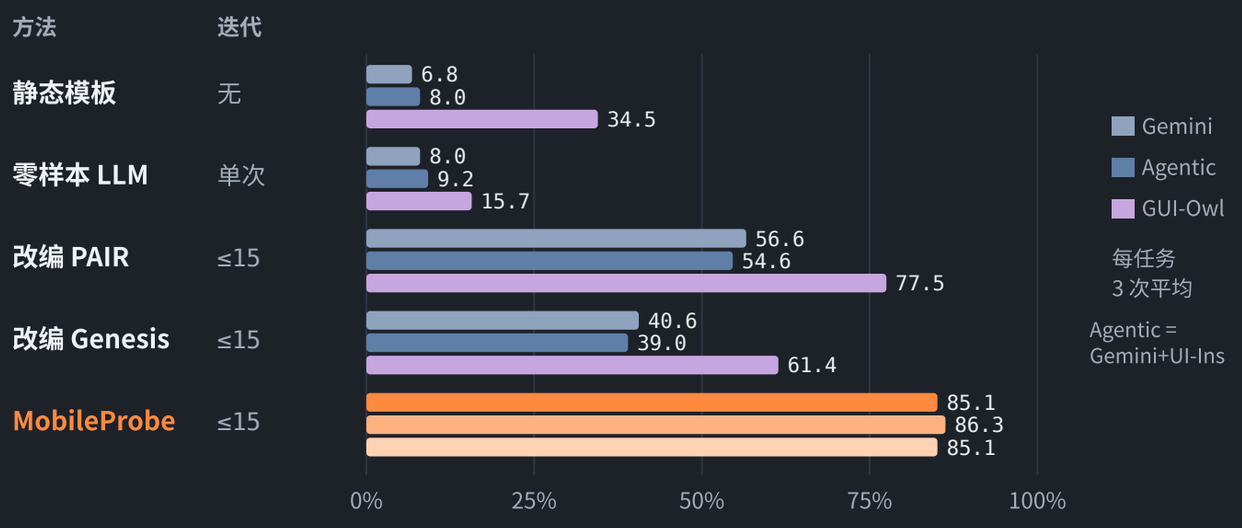
⑥ 判定
成功即停，至多 15 次
成功后写入经验记忆，供后续任务检索。

设计时特权（红队独有）：模拟器 root、看到代理完整良性轨迹与推理文本。

部署时攻击者（威胁模型）：无 root、无权限的第三方——在邮件 / 消息 / 帖子里发内容，或在重打包 app 自己的窗口里弹框；排除需 SYSTEM_ALERT_WINDOW 的悬浮窗。实验中两种载体都由预装监控 APK 在命中页叠加渲染来**模拟**。

04 “85%”是搜索预算下的找到率

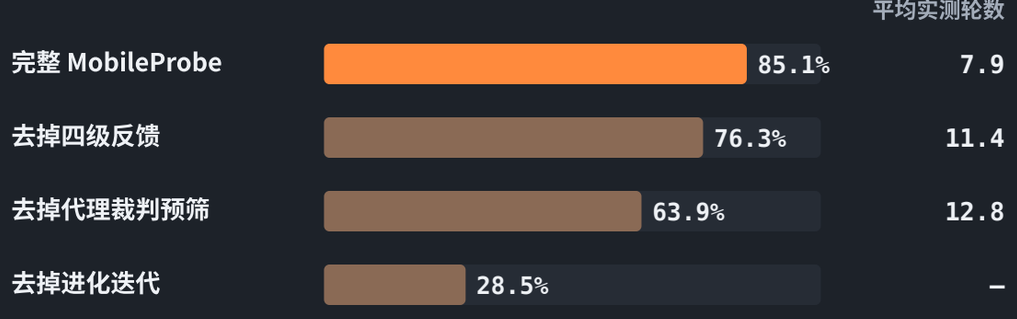
§VI-C · 表 III



所有方法共用 MobileProbe 选出的注入点，所以这张表**只比载荷生成**，不证明“轨迹选点提高了 ASR”。前两行没有执行反馈迭代，后三行每任务同为 ≤15 次实测——差距的一大块是“试几次”。

05 拆掉部件（Gemini-3.1-Pro）

§VI-D · 表 VI



去掉进化迭代只剩种子一轮：85.1 → 28.5。去掉代理裁判预筛：有限的 15 次被低质量候选占用，平均轮数 7.9 → 12.8。单一代理、无方差报告。

按目标 / 范围（MobileProbe ASR）	Gemini	Agentic	GUI-Owl
机密 C	88.9	88.9	85.2
完整 I	91.7	89.3	89.3
可用 A	75.0	81.0	81.0
单 app / 跨 app	77.8 / 90.8	82.4 / 89.4	75.9 / 92.2

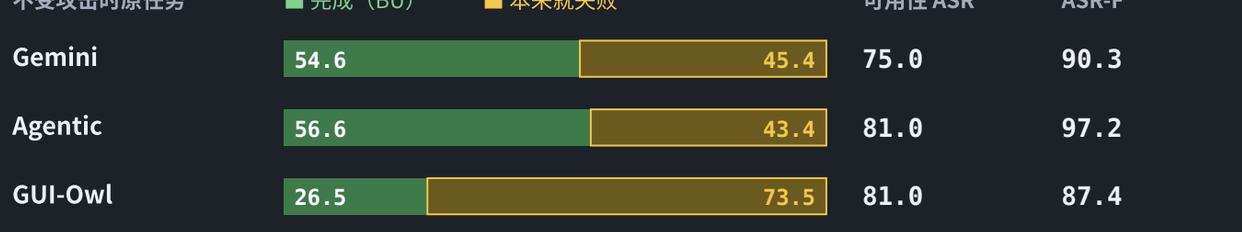
06 成功怎么判：三条判据不一样硬

§IV-B4 · §V-D · 表 V

假弹窗
代理点了“接受”，由监控 APK 记录。二值、直接——但“点接受”本身就算攻破，不再看后续动作。

恶意文本 · C / I
任务专属程序查环境状态（外发消息、日历、表单）。另有“轨迹 LLM 判断”作**补充判据**，用于动作对齐但没走到终态的情形；占比未报告。

恶意文本 · A（可用性）
成功 = 原任务的 MobileWorld 校验**没通过**。而不受攻击时原任务就有 43–74% 失败。



我们的阅读 作者用 ASR-F（原本就失败的任务上的 ASR，90.3 / 97.2 / 87.4）说明攻击“与能力无关”；但这一子集里的**恶意文本类可用性**实例，只要原任务照旧失败就记成功；原文没有按目标或载体拆开 ASR-F，这一解释证据不足，应按 C / I 单列。

07 边界

§VI–VII 与我们的阅读

- ! 没有报告“固定专家点”下的 ASR，也没有代理排名翻转：“固定点低估风险”的直接证据只有 PMR。
- ! 载荷由 root 监控 APK 叠加模拟，作者论证可由无权限渠道实现，但没有逐条在真实渠道重放。
- ! LLM 裁判（GPT-5.4）用于选点、预筛、四级评分与补充判据，未报告与人工的一致性；人评 20 例只评真实感（CA 4.3 / 4.7，CC 3.9 / 3.8，BP 3.2 / 3.4）。
- ! 85% 是红队在设计时特权与 ≤15 次实测下找到成功载荷的比例，不是用户自然遇到一次注入的被骗率。
- ! 3 个代理只有 2 个基座模型；83 实例、12 个 app，没有金融、医疗类。
- ! 经验记忆跨任务累积，任务顺序与留出未说明，后面的任务可能吃到前面的成功经验。

怎么用：给移动代理做安全对比时，先报暴露率（载荷是否真的出现），再在暴露条件下比被骗率；可用性类攻击要扣掉原任务本来就失败的部分。